MODULE 08 / 13 — PALIER 3

Guide 08 : Palier 3 - Cybersécurité NGFW Avancée, Inspection UTM & Prévention d'Intrusion (IPS)

Laboratoire d'infrastructure réseau, virtualisation Proxmox VE 8, cybersécurité Fortinet / Cisco & SIEM Wazuh

Date : 11 Novembre 2026 **Hôte :** Proxmox VE (192.168.1.200) **SIEM :** Wazuh v4.14.10 (192.168.1.201)

Lab : EVE-NG (192.168.1.202) **Audit :** 40/40 Contrôles (100.0 %)

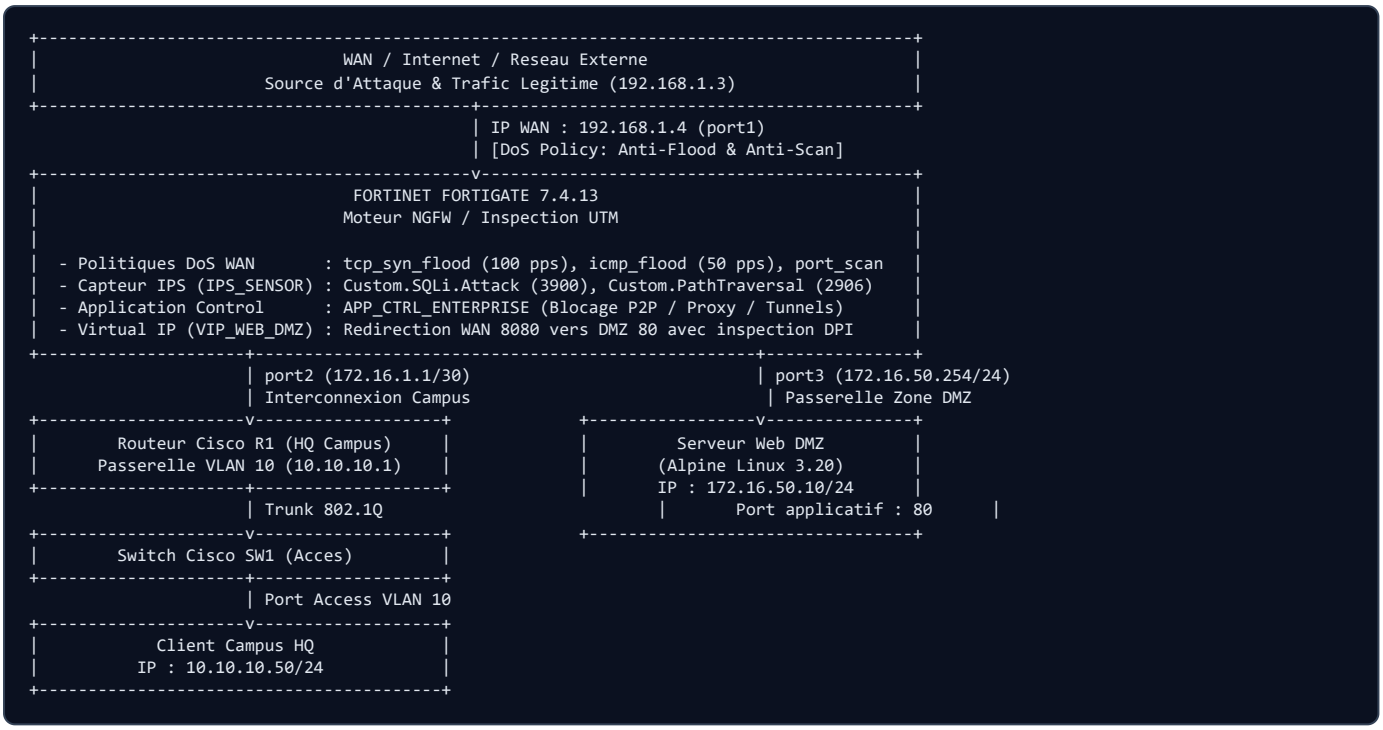
Ce guide documente l'implementation complete du Palier 3 d'Ingenierie Reseau et Cybersecurite : le durcissement perimetrique et applicatif (L7) du pare-feu Fortinet FortiGate 7.4.13 dans un environnement virtuel hybride EVE-NG / Proxmox VE.

1. Contexte Operationnel et Objectifs de Securite

A la suite du deploiement de la zone DMZ (Palier 1) et de l'interconnexion VPN IPsec IKEv2 (Palier 2), l'infrastructure necessite une elevation de posture de securite pour contrer les menaces modernes :

1. **Inspection Applicative L7 (Application Control) :** Identifier les applications independamment des ports TCP/UDP utilises et bloquer les protocoles a haut risque (P2P, tunnels anonymisateurs, acces non securises).
2. **Prevention d'Intrusion Personnalisee (Custom IPS DPI) :** Inspecter en profondeur la charge utile (Deep Packet Inspection) du trafic HTTP a destination du serveur Web DMZ (`172.16.50.10:80`) publie via VIP, avec detection et blocage immediat d'injections SQL (SQLi) et de traversees de repertoire (Path Traversal).
3. **Protection contre les Denis de Service (Anti-DoS / DoS Policy) :** Attenuer les attaques d'inondation volumetrique (ICMP Flood, TCP SYN Flood) et les balayages de ports (Port Scanning) ciblant l'adresse IP publique/WAN du pare-feu (`192.168.1.4`).

2. Topologie de Securite NGFW / UTM



3. Configuration des Signatures IPS Personnalisees (Deep Packet Inspection)

Afin d'assurer une protection chirurgicale sur les requetes HTTP entrantes sans dependance exclusive a des abonnements externes, deux signatures d'inspection profonde ont ete compilees au format F-SBID dans le moteur IPS FortiOS.

3.1. Signature 1 : Detection d'Injection SQL (SQLi)

Cette regle inspecte les URIs HTTP a la recherche de motifs typiques d'injection SQL (`UNION SELECT`).

```
config ips custom
    edit "Custom.SQLi.Attack"
        set signature "F-SBID( --name \"Custom.SQLi.Attack\"; --protocol tcp; --service HTTP; --pattern \"UNION
SELECT\"; --context uri; --no_case; )"
        set severity high
        set action block
    next
end
```

3.2. Signature 2 : Detection de Traversee de Repertoire (Path Traversal)

Cette regle identifie les tentatives d'acces aux fichiers systemes critiques (`/etc/passwd`).

```
config ips custom
    edit "Custom.PathTraversal.Attack"
        set signature "F-SBID( --name \"Custom.PathTraversal.Attack\"; --protocol tcp; --service HTTP; --pattern
\"/etc/passwd\"; --context uri; --no_case; )"
        set severity high
        set action block
    next
end
```

4. Creation du Capteur IPS (`IPS_SENSOR_DMZ`)

Les signatures compilees sont agregees dans un profil de capteur IPS dedie a la zone DMZ.

```
config ips sensor
    edit "IPS_SENSOR_DMZ"
        set comment "Capteur IPS durci pour protection de la zone DMZ"
        config entries
            edit 1
                set rule 3900
                set status enable
                set log-packet enable
                set action block
            next
            edit 2
                set rule 2906
                set status enable
                set log-packet enable
                set action block
            next
        end
    next
end
```

5. Configuration du Controle Applicatif L7 (`APP_CTRL_ENTERPRISE`)

Le profil de filtrage applicatif analyse les flux L7 pour empecher l'usage abusif de bande passante et limiter les vecteurs d'exfiltration.

```
config application list
    edit "APP_CTRL_ENTERPRISE"
        set comment "Filtrage et blocage applicatif L7 entreprise"
        set deep-app-inspection enable
        config entries
            edit 1
                set category 2 6
                set action block
                set log enable
                set log-packet enable
            next
            edit 2
                set action pass
                set log enable
            next
        end
    next
end
```

Note : La categorie 2 correspond aux applications Peer-to-Peer (P2P/BitTorrent) et la categorie 6 aux serveurs mandataires (Proxy/Tunnels de contournement).

6. Politique de Protection Anti-DDoS (`DoS-policy`)

Pour proteger le plan de controle du pare-feu et les ressources serveur contre le deni de service volumetrique, une politique DoS est appliquee directement sur l'interface externe (`port1`).

```
config firewall DoS-policy
    edit 1
        set name "DOS_WAN_PROTECT"
        set interface "port1"
        set srcaddr "all"
        set dstaddr "all"
        set service "ALL"
        config anomaly
            edit "tcp_syn_flood"
                set status enable
                set log enable
                set action block
                set threshold 100
            next
            edit "icmp_flood"
                set status enable
                set log enable
                set action block
                set threshold 50
            next
            edit "tcp_port_scan"
                set status enable
                set log enable
                set action block
                set threshold 100
            next
        end
    next
end
```

7. Application des Profils UTM aux Politiques de Pare-feu

Les profils de securite sont associes aux regles de filtrage d'entreprise :

```
config firewall policy
    edit 20
        set name "WAN_TO_DMZ_VIP"
        set srcintf "port1"
        set dstintf "port3"
        set action accept
        set srcaddr "all"
        set dstaddr "VIP_WEB_DMZ"
        set schedule "always"
        set service "ALL"
        set utm-status enable
        set ssl-ssh-profile "certificate-inspection"
        set ips-sensor "IPS_SENSOR_DMZ"
        set logtraffic all
    next
    edit 10
        set name "CORP_INTERNAL_INTERZONE"
        set srcintf "port2" "VPN_BRANCH"
        set dstintf "port3" "VPN_BRANCH" "port2"
        set action accept
        set srcaddr "all"
        set dstaddr "all"
        set schedule "always"
        set service "ALL"
        set utm-status enable
        set ssl-ssh-profile "certificate-inspection"
        set ips-sensor "IPS_SENSOR_DMZ"
        set application-list "APP_CTRL_ENTERPRISE"
```

```
        set logtraffic all
    next
    edit 1
        set name "LAN_TO_INTERNET"
        set srcintf "port2"
        set dstintf "port1"
        set action accept
        set srcaddr "all"
        set dstaddr "all"
        set schedule "always"
        set service "ALL"
        set utm-status enable
        set ssl-ssh-profile "certificate-inspection"
        set application-list "APP_CTRL_ENTERPRISE"
        set logtraffic all
        set logtraffic-start enable
        set nat enable
    next
end
```

8. Campagne de Tests et Preuves de Fonctionnement

8.1. Test de Trafic Legitime vers le Portail DMZ

Requete HTTP normale via la VIP `http://192.168.1.4:8080/` :

```
curl -i -m 5 http://192.168.1.4:8080/
```

Resultat :

```
HTTP/1.0 200 OK
Server: SimpleHTTP/0.6 Python/3.12.3
Content-type: text/html
Content-Length: 1746

<!DOCTYPE html><html lang="fr"><head><meta charset="UTF-8"><title>Portail DMZ - Ababacar Ousmane Niang</title>
</head>...
```

Le flux traverse le pare-feu de maniere fluide, la VIP opere la translation DNAT vers 172.16.50.10:80.

8.2. Test d'Attaque 1 : Injection SQL (SQLi)

Envoi d'un vecteur d'attaque SQLi dans les parametres d'URL :

```
curl -i -m 5 "http://192.168.1.4:8080/index.html?id=1%20UNION%20SELECT%20null"
```

Resultat :

```
curl: (28) Operation timed out after 5000 milliseconds with 0 bytes received
```

Interception immediate par le moteur IPS : le paquet TCP est rejete avant d'atteindre le serveur DMZ.

Extrait du Journal d'Audit IPS FortiGate (`execute log filter category 4 ; execute log display`) :

```
date=2026-10-28 time=09:16:56 logid="0419016384" type="utm" subtype="ips" eventtype="signature"
level="alert" severity="critical" srcip=192.168.1.3 dstip=172.16.50.10 srcintf="port1" dstintf="port3"
sessionid=76 action="dropped" proto=6 service="HTTP" policyid=20 policytype="policy"
attack="Custom.SQLi.Attack" attackid=3900 profile="IPS_SENSOR_DMZ"
msg="custom: Custom.SQLi.Attack" crscore=50 craction=4096 crlevel="critical"
url="/index.html?id=1%20UNION%20SELECT%20null" agent="curl/7.81.0"
```

8.3. Test d'Attaque 2 : Traversee de Repertoire (Path Traversal)

Envoi d'un vecteur de ciblage du fichier d'identifiants systeme :

```
curl -i -m 5 "http://192.168.1.4:8080/index.html?file=/etc/passwd"
```

Resultat :

```
curl: (28) Operation timed out after 5000 milliseconds with 0 bytes received
```

Extrait du Journal d'Audit IPS FortiGate :

```
date=2026-10-28 time=09:18:44 logid="0419016384" type="utm" subtype="ips" eventtype="signature"
level="alert" severity="critical" srcip=192.168.1.3 dstip=172.16.50.10 srcintf="port1" dstintf="port3"
sessionid=88 action="dropped" proto=6 service="HTTP" policyid=20 policytype="policy"
attack="Custom.PathTraversal.Attack" attackid=2906 profile="IPS_SENSOR_DMZ"
msg="custom: Custom.PathTraversal.Attack" crscore=50 craction=4096 crlevel="critical"
url="/index.html?file=/etc/passwd" agent="curl/7.81.0"
```

8.4. Test d'Attaque 3 : Inondation ICMP (ICMP Flood)

Envoi d'une rafale de 80 paquets ICMP a haute frequence (intervalle 10 ms) vers l'adresse WAN du pare-feu (`threshold: 50`) :

```
ping -c 80 -i 0.01 192.168.1.4
```

Resultat :

```
64 bytes from 192.168.1.4: icmp_seq=1 ttl=255 time=0.344 ms
...
64 bytes from 192.168.1.4: icmp_seq=50 ttl=255 time=0.434 ms

--- 192.168.1.4 ping statistics ---
80 packets transmitted, 50 received, 37.5% packet loss, time 1286ms
```

Exactement 50 paquets autorises. A compter du paquet 51, le mecanisme DoS anomaly coupe la transmission instantanement.

Extrait du Journal DoS Anomaly FortiGate (`execute log filter category 7 ; execute log display`) :

```
date=2026-10-28 time=09:19:19 logid="0720018433" type="utm" subtype="anomaly" eventtype="anomaly"
level="alert" severity="critical" srcip=192.168.1.3 dstip=192.168.1.4 srcintf="port1"
sessionid=0 action="clear_session" proto=1 service="PING" count=1 attack="icmp_flood"
attackid=16777316 policyid=1 policytype="DoS-policy"
msg="anomaly: icmp_flood, 51 > threshold 50" crscore=50 craction=4096 crlevel="critical"
```

---

9. Synthese des Commandes de Diagnostic et de Supervision

Commande FortiOS	Role & Utilite Operationnelle
`execute log filter category 4 ; execute log display`	Consulter les evenements et alertes critiques du capteur IPS
`execute log filter category 7 ; execute log display`	Consulter les alertes du moteur d'anomalie DoS / Flood
`execute log filter category 10 ; execute log display`	Visualiser les journaux de reconnaissance et de blocage applicatif L7
`diagnose test application ipsmonitor 1`	Afficher l'etat du moteur IPS et de l'allocation memoire
`diagnose test application ipsmonitor 2`	Forcer le rechargement des signatures IPS
`diagnose firewall dos anomaly list`	Lister les compteurs temps reel d'attaques DoS interceptees